Hyperscalers américains et cloud souverain

Document de synthèse de comparaison • Olivier HIMBLOT • 15 octobre 2026 • V2 documentaire — base ReCyF

Base de l’exercice : ReCyF v2.5 du 17/03/2026, document de travail. Les critères fournisseur, architecture et migration sont reliés à ses mesures, avec Cloud Act comme analyse juridique et SecNumCloud comme garantie d’offre distincte.

Compétence : Contribuer à la conception d’une infrastructure sécurisée.

Critère : comparer hyperscalers américains et solutions cloud souveraines, puis argumenter un plan de migration au regard des risques identifiés dans le cadre du Cloud Act.

Décision proposée	Justification	Conditions avant exécution
Préparer une migration ciblée de la partie sensible du CRM ; instruire séparément le maintien ou la migration de l’analytics.	Données clients et IBAN, absence de contrat et d’analyse formalisée chez CloudPeak ; besoin de réduire l’exposition juridique tout en conservant le service.	Offre cible vérifiée, analyse juridique, contrat, compatibilité, coût et reprise testés ; approbation de la direction.
Assurer une transition contrôlée et réversible.	Une bascule immédiate non préparée peut interrompre le SI clientèle ; le dossier exige sa disponibilité continue.	Le maintien temporaire n’est pas une régularisation juridique. Toute non-conformité établie exige un arbitrage adapté, sans attendre le calendrier indicatif.

Statut : travail de conception à partir du scénario fictif ÉnergieAlp. Comparaison qualitative des familles d’offres, analyse des risques et plan proposés ; aucun fournisseur retenu, devis reçu, contrat signé, pilote exécuté ou migration réalisée. Les constats, hypothèses et preuves attendues sont distingués.

Lecture du document : contexte et périmètre ; risques Cloud Act ; comparaison ; choix d’architecture ; plan de migration ; recette et retour arrière ; preuves et sources. Les acquis du module Cloud/IAM servent à la méthode, sans prouver une configuration de CloudPeak.

ReCyF — critères de comparaison et de migration

Référentiel principal imposé pour l'exercice : ReCyF v2.5 du 17/03/2026, document de travail. Source officielle : https://messervices.cyber.gouv.fr/documents-ressources/20260317_NIS_V2_ReCyF_v2.5.pdf

Hypothèse EE documentaire : les mesures EE sont retenues sous réserve de confirmation du périmètre. SecNumCloud ne démontre pas automatiquement l'atteinte des objectifs ReCyF du SI client. Les références ci-dessous sont les critères de conception, pas des attestations de mise en œuvre.

Risque / choix	MAC ReCyF	Critère à contrôler dans l'offre et la migration
RC-01 / RC-05	3.A.1-EI/EE ; 3.B.1-EI/EE ; 16.2-EE ; 16.3-EE	Juridiction, dépendances et accès réels dans l'analyse ; contrat et décision de traitement ; Cloud Act étudié avec sources juridiques distinctes.
RC-02 / RC-03	7.B.1-EI/EE ; 7.B.3-EI/EE ; 8.1-EI/EE ; 8.3-EE ; 10.C.2-EI/EE	Limiter flux et droits, chiffrer accès, MFA distant ; examiner contrôle des clés et du clair ; minimisation/anonymisation à démontrer.
RC-04	13.1-EI/EE ; 13.2-EI/EE ; 13.4-EE ; 13.6-EE ; 15.4-EE	Définir DMIA/PRD et tester restauration, continuité et réversibilité ; inclure migration et sortie dans les exercices.
Cible et administration	5.A.1-EI/EE ; 11.A.1-EI/EE ; 18.3-EE ; 19.1-EE ; 19.10-EE	Cartographier, durcir et séparer administration ; tester compte dédié, chemin d'administration et protection des communications.
Surveillance fournisseur	3.B.2-EI/EE ; 17.4-EE ; 17.5-EE ; 20.4-EE ; 20.5-EE	Revue des engagements, audits et correction ; traces pertinentes et conservation au moins trois mois selon obligations applicables.

Exigences à la recette : comptes et flux autorisés/refusés ; MFA distant avec au moins un facteur de connaissance (8.3-EE) ; restauration testée au moins annuellement (13.2-EI/EE), DMIA et PRD approuvés par activité/service (13.4-EE), PCA/PRA (13.6-EE), administration dédiée (19.1-EE et mesures associées), traces conservées au moins trois mois (20.5-EE) selon les autres obligations.

Approche risques : 16.2-EE et 16.3-EE relient activités/services, SI, traitements et décision sur risques résiduels. Revue au minimum tous les trois ans et après évolution/incident selon 16.4-EE ; une migration change le contexte et déclenche réexamen. Le contrat fournisseur et sa vérification périodique relèvent de 3.B.1-EI/EE et 3.B.2-EI/EE.

Les choix locaux (deux offres à comparer, jalons J+7/J+30, fréquence semestrielle de tests) ne sont pas présentés comme des citations du ReCyF. Aucun fournisseur ni offre précise n'a été évalué sur pièces dans le scénario.

1. Périmètre et faits du scénario

Actif / service	Données et criticité proposées	Situation et responsable
EA-03 — CRM / facturation	Identité, adresse, IBAN et historique de consommation ; C/I/D/T = 4/4/4/4.	Hébergement partiel CloudPeak ; DSI responsable. SI clientèle disponible en continu.
EA-04 — Analytics	Consommations individuelles et agrégées, prévisions de charge ; C/I/D/T = 3/4/3/3.	Hébergement CloudPeak ; DSI responsable. I4 prudent et D3 provisoire à confirmer avec métiers.
EA-01 / EA-02 / EA-05 — dépendances	SCADA, compteurs et VPN ne sont pas présumés hébergés chez CloudPeak.	Cartographier les échanges avec CRM/analytics avant modification ; aucune migration industrielle prévue dans ce périmètre.

Source des faits : dossier entreprise ÉnergieAlp, §1 à §5. Gestionnaire de réseau électrique, environ 650 salariés, 280 000 clients et 30 M€ de CA 2025. CloudPeak est une filiale européenne d’un groupe américain ; le scénario indique absence de contrat et d’analyse de risque documentée formalisée pour cet hébergement.

Établi par le dossier	Information non fournie	Conséquence pour la décision
CRM partiel et analytics externalisés.	Entité contractante précise, régions de production/sauvegarde, sous-prestataires, accès support et contrôle des clés.	Demander les pièces ; ne pas supposer hébergement aux États-Unis ou accès effectif des autorités.
Disponibilité continue du SI clientèle et fenêtres de maintenance validées.	Volumes, dépendances, débit, architecture, licences, tolérance aux erreurs et objectifs de reprise.	Aucun chiffrage ni durée de bascule garantie avant mesure et validation métier.
Qualification CloudPeak non documentée.	Offre exacte, garanties, statut SecNumCloud éventuel et périmètre.	Ne pas assimiler CloudPeak à une offre réelle d’un hyperscaler précis ni à une offre qualifiée.

Hyperscaler : fournisseur cloud de très grande échelle ; les groupes américains AWS, Microsoft et Google illustrent cette catégorie. Ces exemples ne constituent ni une sélection ni une attestation sur une offre ou une région particulière. Une offre européenne non qualifiée est distinguée ci-après d’une offre qualifiée SecNumCloud.

2. Cloud Act : risques et réponses de conception

Le Cloud Act concerne notamment la production de données contrôlées par un fournisseur soumis à la juridiction américaine ; la localisation hors des États-Unis ne suffit pas à écarter cette possibilité. Examiner l'entité visée, sa juridiction et sa possession, garde ou maîtrise des données. La filiation américaine de CloudPeak justifie l'analyse, sans prouver une demande ni un accès au clair. Source S1.

Risque / périmètre	Scénario et conséquence	Réduction proposée	Limite / preuve nécessaire
RC-01 — EA-03/04	Demande légale à une entité pouvant produire les données : atteinte possible à la confidentialité.	Étudier juridiction et contrôle ; comparer offre cible et dépendances ; engagements de gestion des demandes lorsque permis.	Analyse juridique individualisée ; un contrat ne neutralise pas une injonction. Aucune demande avérée dans le dossier.
RC-02 — EA-03	Accès fournisseur au dossier client ou aux IBAN, légal ou compromis.	Moindre privilège, MFA, traces, séparation des responsabilités et choix de chiffrement/gestion des clés.	Vérifier qui peut obtenir le clair pendant stockage et traitement ; chiffrement fournisseur insuffisant à lui seul. S3.
RC-03 — EA-04	Réidentification ou usage indu de consommations dites agrégées.	Réduire données et granularité ; pseudonymiser ou anonymiser si démontré ; séparer jeux identifiants et analyses.	Pseudonymisation ne retire pas le caractère personnel ; l'agrégation seule ne prouve pas l'anonymisation.
RC-04 — EA-03/04	Enfermement et échec de sortie : indisponibilité, données manquantes ou coût imprévu.	Formats exportables, documentation, clause de sortie, copie maîtrisée et test de reprise sur cible.	Mesurer volume, temps, coût et dépendances aux API/licences ; portabilité non présumée.
RC-05 — EA-03/04	Transferts hors EEE ou accès tiers sans garanties adaptées.	Cartographier données, sauvegardes, support, journaux et services annexes ; vérifier mécanismes RGPD si requis.	Aucun transfert effectif établi ; risque Cloud Act et transfert international sont deux questions distinctes. S4.

Priorité de traitement : CRM sensible et lacunes contractuelles avant nouveau développement ; analytics selon nécessité des données individuelles et dépendances métier. Probabilités, montants de perte et risque résiduel ne sont pas chiffrés faute de pièces. Les risques RC-01 à RC-05 restent ouverts jusqu'à décision documentée et contrôles.

3. Comparaison qualitative des familles d’offres

Il s’agit de tendances et garanties à confronter à l’offre exacte, pas d’un classement de produits testés. Aucun prix, score fournisseur ou niveau de service réel n’est inventé. Source S2 pour SecNumCloud ; les autres critères sont une grille de conception locale.

Critère	Hyperscaler américain	Offre européenne non qualifiée	Offre qualifiée SecNumCloud
Juridiction / souveraineté	Exposition américaine à examiner sur entité et données contrôlées ; région UE ne suffit pas.	Siège UE seul insuffisant : contrôle du groupe, dépendances et accès à vérifier.	Garanties du référentiel sur l’offre et son exploitation, dont protection face aux lois extraterritoriales ; périmètre et validité à contrôler.
Localisation	Régions à choisir et vérifier pour données, copies, support et services annexes.	Exiger les mêmes preuves ; étiquette européenne ne documente pas tous les flux.	Vérifier périmètre qualifié et lieux réels ; qualification ne dispense pas de cartographie.
Maturité / fonctions	Catalogues généralement étendus ; facilité d’intégration potentielle, dépendance aux services propriétaires à maîtriser.	Fonctions, support, capacité et intégrations variables selon offre ; vérifier compatibilité.	Qualification apporte une assurance sur le périmètre ; adéquation CRM/analytics et support métier restent à tester.
Accès et clés	Capacités de sécurité à configurer ; vérifier accès fournisseur au clair et aux clés.	Même responsabilité client ; aucun contrôle des clés présumé.	Même besoin de sécuriser l’application, les habilitations et la gestion des clés côté client.
Réversibilité	Vérifier API, formats, licences, flux sortants et dépendances managées.	Ne pas présumer absence d’enfermement ; export/restauration à tester.	Vérifier capacités contractuelles et testées de sortie du service exact.
Coût global	Comparer coût d’usage et services nécessaires, exploitation, sortie et compétences.	Comparer même périmètre, support, protections et capacité ; aucun avantage de prix présumé.	Inclure niveau de garantie, adaptation, double exploitation et formation ; devis indispensable.
Continuité	Architecture, engagements et reprise à vérifier ; grande échelle ne prouve pas la résilience du CRM.	Capacité, dépendances et reprise à tester sur scénario métier.	Qualification ne prouve pas le respect des objectifs de disponibilité du service client.

Conclusion comparative : une offre européenne non qualifiée peut être adaptée si ses garanties sont établies ; une offre qualifiée fournit une assurance supplémentaire définie, sans certifier le CRM du client. Le mot « souverain » et une qualification en cours ne remplacent pas l’examen de l’offre et de son périmètre.

4. Choix argumenté et infrastructure cible proposée

Option	Réponse aux risques	Arbitrage proposé
O1 — Maintien durable chez CloudPeak	Évite une migration immédiate et conserve les dépendances existantes ; RC-01/02/05 subsistent tant que juridiction, accès et garanties restent inconnus.	Non justifié en l'état : contrat/analyse absents. Réexamen possible seulement sur garanties et décision explicites.
O2 — Migration intégrale immédiate	Peut réduire certaines expositions si cible vérifiée ; introduit risque de rupture, erreur de données, incompatibilité et coût non mesuré.	Écartée comme exécution immédiate : conditions de continuité et de recette non établies.
O3 — Migration ciblée, par étapes	Traite d'abord CRM et IBAN ; sépare décision analytics ; permet pilote, réversibilité et vérification des garanties.	Option recommandée à instruire : cible qualifiée à examiner prioritairement pour données sensibles, sous réserve d'adéquation et coût.

Composant cible / flux	Principe de sécurité proposé	Risque visé et réserve
CRM sensible → offre cible évaluée	Habilitations nominatives, MFA administration, segmentation, traces et stockage protégé ; clés et accès au clair analysés.	RC-01/02/05 ; sélectionner le service exact, sans supposer qu'il est déjà qualifié.
Données nécessaires → analytics maintenu ou migré	Réduire les données en amont ; séparer identifiants si faisable ; flux authentifiés et chiffrés selon conception validée.	RC-02/03/05 ; maintien seulement si besoin des données et garanties acceptables ; pseudonymisation à tester.
Copies / supervision / preuve → périmètre maîtrisé	Sauvegardes restaurables et accès séparés ; accès journaux limité ; contrôle de cohérence avant et après bascule.	RC-04 ; emplacement et contrôle juridique des copies à inclure dans l'analyse.

Répartition proposée : direction arbitre orientation et moyens ; DSI porte CRM/analytics et migration ; RSSI coordonne analyse et contrôles ; appui juridique à désigner ; métiers valident fonctions et objectifs de reprise. Production est consultée pour les dépendances supervision ; seul le RSSI valide une dérogation de sécurité. Aucune architecture exacte n'est déclarée déployée.

5. Plan de migration relié aux risques

J = approbation future du lancement de l'étude. Jalons indicatifs, sans engagement de déploiement : pièces/risques à J+7, décision d'orientation visée J+30 ; pilote et bascule datés après mesures. Une non-conformité juridique établie peut imposer un traitement plus rapide, sans attendre ces jalons.

Phase / risques	Travail et pilote	Condition de passage / preuve
1 — Cadrer et protéger RC-01/02/05	DSI, RSSI, juridique proposé : identité fournisseur, régions, accès, clés, flux et contrats ; réduire accès excessifs si confirmés, éviter extension non évaluée.	Analyse documentée et mesures urgentes décidées ; maintien transitoire réexaminé et borné. Aucun accord interne ne régularise un traitement illicite.
2 — Comparer et contractualiser RC-01 à RC-05	DSI consulte au moins deux offres comparables ; vérifier qualification exacte, garanties, compatibilité, coûts, incident et réversibilité avec juridique/RSSI.	Direction examine dossier comparatif et risque résiduel ; contrat signé avant engagement du service selon cadre applicable.
3 — Piloter sur données maîtrisées RC-02/03/04	DSI construit environnement isolé ; données fictives ou anonymisation démontrée ; tester import/export, fonctions, performance, droits et contrôle des clés.	Résultats de recette comparés aux objectifs métiers ; pas d'exposition nouvelle de données réelles sans cadre validé.
4 — Préparer la reprise RC-04	DSI inventorie dépendances, réalise copie sauvegardée et restauration testée ; mesure synchronisation, cohérence et temps de reprise ; prépare retour arrière.	Objectifs RTO/RPO et critères de bascule approuvés ; intégrité et restauration vérifiées, clés récupérables.
5 — Basculer par lot RC-02/04	DSI et métiers : synchronisation finale contrôlée, validation données puis flux ; fenêtre CRM validée nuit/hors pics ; surveillance renforcée.	Décision go/no-go sur preuves. Maintenir service selon exigences ; ne pas promettre zéro coupure sans architecture et essais correspondants.
6 — Stabiliser et sortir RC-01/02/04/05	DSI : recette métier, suivi incidents, retrait comptes/sessions, restitution, fermeture et effacement selon conservation légale et engagements.	Recette signée, accès retirés testés, preuves de restitution/effacement et mise à jour registre/matrice/risques.

Décision analytics : si données individuelles indispensables et garanties insuffisantes, inclure le traitement dans la migration. Si minimisation et garanties établies permettent un maintien, l'argumenter séparément avec responsable, contrôles et date de revue. Aucun transfert de tout le SCADA n'est déduit de ce plan.

6. Recette, retour arrière et coût de décision

Contrôle avant bascule	Résultat attendu	Preuve à conserver
Données et fonctions	Enregistrements, contrats, factures et historiques cohérents selon critères métiers ; aucune divergence inexpliquée ; fonctions critiques validées.	Comparatif source/cible, échantillons et contrôles complets pertinents, anomalies et recette métier ; empreintes seulement lorsqu'adaptées au format.
Accès / clés / traces	Accès valide autorisé ; hors droit, sans facteur ou après retrait refusé ; actions attribuables ; récupération des clés possible selon conception.	Exports anonymisés, tests positifs/négatifs, journaux et essai de récupération isolé.
Disponibilité / reprise	Délai mesuré et perte de données compatibles avec objectifs approuvés ; restauration et retour arrière éprouvés hors production.	Protocole, horodatage, résultats, limites et autorisation de bascule.
Dépendances et sortie	Flux, licences et API compatibles ; export complet réutilisable sur environnement de reprise.	Inventaire, résultats de bout en bout, dossier de réversibilité et coût estimé.

Go/no-go proposé : DSI présente résultats, métiers valident fonctions et cohérence, RSSI examine les écarts de sécurité, direction arbitre selon responsabilités à formaliser. En cas de divergence de données, défaut d'accès, échec de reprise ou interruption dépassant le seuil métier approuvé : suspendre le lot et décider du retour arrière prévu. Aucun seuil horaire arbitraire n'est présenté comme validé.

Retour arrière : définir avant bascule le système faisant autorité pour les écritures, limiter leur divergence, journaliser les opérations, prévoir leur réconciliation puis contrôler l'intégrité après restauration. Ne pas simplement rediriger vers une ancienne base devenue obsolète. Conserver l'environnement source uniquement dans un cadre et une durée approuvés.

Coût global à comparer sur une même durée	Données à obtenir
TCO = exploitation récurrente + transition + sortie	Hébergement, stockage, sauvegardes, réseau, support, licences, sécurité, exploitation et formation ; audit/qualification pertinente au besoin ; migration, adaptation, double exploitation, tests et retrait.
Hypothèses et sensibilité	Volumes actuels/croissance, consommation et trafic, durée contractuelle, engagements et frais ; devis datés et scénarios comparables. Aucun montant disponible : décision économique non finalisée.

7. Preuve de travail, limites et sources

Critère évalué	Travail présenté	Reste à établir
Comparer hyperscalers et cloud souverain	Comparaison qualitative à trois familles : américain, européen non qualifié, offre qualifiée ; critères juridiques, techniques, coût et réversibilité.	Offres exactes, qualification vérifiée, devis et résultats du pilote ; aucun classement commercial final.
Argumenter le plan face au Cloud Act	RC-01 à RC-05 reliés aux mesures et six phases ; comparaison de trois options ; migration CRM ciblée et décision analytics distincte.	Avis juridique, décision direction, garanties fournisseur, contrat et niveau de risque résiduel accepté par les instances compétentes.
Concevoir une infrastructure sécurisée	Cible logique, droits, clés, flux, sauvegardes, critères de recette, continuité et retour arrière.	Schéma détaillé après inventaire, paramètres propres aux produits, essais et preuves de mise en œuvre.

Conclusion : ce document étaye un travail de comparaison et de conception. La recommandation est conditionnelle et soumise aux données manquantes ; aucune migration réalisée, conformité globale, approbation du formateur ou offre sélectionnée n’est attestée.

Sources officielles consultées le 15 octobre 2026 ; formulations de synthèse :

ReCyF — base de conception : https://messervices.cyber.gouv.fr/documents-ressources/20260317_NIS_V2_ReCyF_v2.5.pdf ; v2.5 du 17/03/2026, pp. 11, 16–18, 20–26 et 29–38.

S1 — DOJ, Cloud Act et juridiction/contrôle des données : https://www.justice.gov/opa/press-release/file/1153446/dl

S2 — ANSSI, cloud et SecNumCloud : https://cyber.gouv.fr/enjeux-technologiques/cloud/ ; FAQ : https://cyber.gouv.fr/enjeux-technologiques/cloud/faq-qualification-secnumcloud/

S3 — CNIL, chiffrement et accès du fournisseur : https://www.cnil.fr/fr/les-pratiques-de-chiffrement-dans-linformatique-en-nuage-cloud-public

S4 — CNIL, RGPD (art. 28, 32 et chapitre V selon les faits) : https://www.cnil.fr/fr/reglement-europeen-protection-donnees

Scénario : docs/droit-conformite/annexes/dossier-entreprise-energiealp.md, §1–6. Analyse locale : docs/droit-conformite/it-2/debrief-matrice-cloud-act-politique-securite.md, sections 4–5 ; registre V0 : it-2/registre-actifs-critiques.md.

Conservation des futures preuves : identifiant, actif/risque, auteur, date/heure/fuseau, origine, méthode, attendu/constaté, limites, version et emplacement contrôlé ; copie anonymisée pour le formateur. Ce document et sa source sont les seules pièces produites ici, sans capture technique simulée présentée comme réelle.